

Programme

TD de Cybersécurité

Introduction
: la cybersécurité
Cryptographie
Menaces en cybersécurité
Protections
Gestion de la sécurité
Manipulations : Wireshark & Kali Linux

Exercices et Travaux Dirigés

Table des matières

1	Programme de cybersécurité	3
2	Introduction : la cybersécurité	4
3	La cryptographie	5
4	Les menaces en cybersécurité	7
5	Les protections en cybersécurité	9
6	Gestion de la sécurité	11
7	Manipulations : communications sécurisées	13

1 Programme de cybersécurité

Exercice 1 – QCM : Programme et certifications en cybersécurité

Pour chaque question, choisir la bonne réponse :

1. Parmi les domaines suivants, lequel n'est **pas** un domaine fondamental de la cybersécurité ?
 - (a) La cryptographie
 - (b) La gestion de projet
 - (c) La protection des systèmes
 - (d) La gestion des incidents
2. La certification CompTIA Security+ couvre principalement :
 - (a) L'audit financier
 - (b) Les fondamentaux de la sécurité informatique
 - (c) Le développement logiciel
 - (d) La conception de réseaux
3. Le référentiel NIST Cybersecurity Framework (CSF) comporte combien de fonctions principales ?
 - (a) 3
 - (b) 5
 - (c) 7
 - (d) 10
4. Quel organisme publie les normes de la série ISO 27000 ?
 - (a) L'IANA
 - (b) L'ISO/IEC JTC 1/SC 27
 - (c) Le NIST
 - (d) L'ANSSI
5. L'ANSSI est :
 - (a) Une agence européenne de cybersécurité
 - (b) L'autorité nationale française de sécurité des systèmes d'information
 - (c) Un certificat de sécurité
 - (d) Un protocole de chiffrement

2 Introduction : la cybersécurité

Exercice 2 – La triade CID : Définitions et scénarios

1. Donner une définition précise de chacun des trois principes fondamentaux de la sécurité de l'information :
 - (a) **Confidentialité**
 - (b) **Intégrité**
 - (c) **Disponibilité**
2. Pour chaque scénario ci-dessous, identifier quel principe de la triade CID est **violé** :
 - (a) Un employé accède au dossier médical d'un collègue sans autorisation.
 - (b) Un site web est rendu inaccessible par une attaque DDoS.
 - (c) Un relevé bancaire est modifié par un attaquant.
 - (d) Un mot de passe est envoyé en clair dans un courriel.
 - (e) Une base de données est corrompue suite à une insertion malveillante.
 - (f) Un serveur est éteint pendant une maintenance non planifiée.
3. Citer deux autres propriétés de sécurité complémentaires à la triade CID et les définir brièvement.

Exercice 3 – QCM : Introduction : la cybersécurité

Pour chaque question, choisir la bonne réponse :

1. La cybersécurité a pour objectif principal de :
 - (a) Accélérer les réseaux
 - (b) Protéger les systèmes, réseaux et données contre les attaques
 - (c) Développer de nouvelles applications
 - (d) Réduire les coûts informatiques
2. Le principe de « défense en profondeur » consiste à :
 - (a) Utiliser un seul pare-feu puissant
 - (b) Superposer plusieurs couches de sécurité
 - (c) Chiffrer uniquement les données sensibles
 - (d) Restreindre l'accès physique
3. Une menace interne est :
 - (a) Un virus provenant d'Internet
 - (b) Un employé mécontent qui vole des données
 - (c) Un attaquant externe qui exploite une faille

(d) Une coupure de courant

4. Le principe du moindre privilège stipule que :

- (a) Tous les utilisateurs doivent avoir les mêmes droits
- (b) Un utilisateur ne doit avoir que les permissions minimales nécessaires
- (c) Les administrateurs n'ont besoin d'aucun privilège
- (d) Les mots de passe doivent être courts

5. Le RGPD concerne principalement :

- (a) La sécurité des réseaux
- (b) La protection des données personnelles
- (c) Le chiffrement des communications
- (d) La certification des produits

Exercice 4 – Attaquants et motivations

1. Compléter le tableau suivant concernant les types d'attaquants :

Type d'attaquant	Motivation	Cible privilégiée	Exemple
Hacker éthique			
Black hat			
APT			
Insider			
Hacktiviste			
Cybercriminel			
Script kiddie			

2. Expliquer la différence entre un **white hat**, un **black hat** et un **grey hat**.

3. Pourquoi les menaces internes sont-elles souvent considérées comme plus dangereuses que les menaces externes ?

3 La cryptographie

À retenir : Vocabulaire de la cryptographie

Chiffrement (encryption) : transformer un texte clair en texte illisible à l'aide d'une clé.

Déchiffrement (decryption) : opération inverse, retrouver le texte clair.

Cryptanalyse : tenter de casser un chiffrement sans connaître la clé.

Cryptographie : science du chiffrement (du grec *kryptos* = caché, *graphein* = écrire).

Exercice 5 – Chiffrement symétrique vs asymétrique

1. Compléter le tableau de comparaison ci-dessous :

Critère	Symétrique	Asymétrique
Nombre de clés		
Vitesse		
Exemples d'algos		
Gestion des clés		
Cas d'utilisation		

2. Expliquer pourquoi le chiffrement asymétrique est plus lent que le chiffrement symétrique.
3. Dans la pratique, comment combine-t-on les deux types de chiffrement ? Donner un exemple concret (HTTPS/TLS).

Exercice 6 – Algorithmes et protocoles de chiffrement

1. Associer chaque algorithme à sa catégorie :

AES	...
RSA	...
DES	...
3DES	...
Diffie-Hellman	...
SHA-256	...
MD5	...
ECC	...
Blowfish	...
RC4	...

Catégories :

A. Chiffrement symétrique

B. Chiffrement asymétrique

C. Fonction de hachage

2. Pourquoi l'algorithme DES est-il considéré comme obsolète ?
3. Quelle est la différence entre un algorithme de chiffrement par bloc et par flux ?

Exercice 7 – Hachage et signatures numériques

1. Expliquer la différence entre le **chiffrement** et le **hachage**.
2. Quel est le rôle d'un **HMAC** (Hash-based Message Authentication Code) ?
3. Décrire le processus de création et de vérification d'une **signature numérique** :

- (a) Comment le signataire crée-t-il la signature ?
- (b) Comment le vérificateur contrôle-t-il la signature ?
- 4. Pourquoi utilise-t-on un condensat (hash) dans les signatures numériques plutôt que de signer directement le message entier ?
- 5. Donner deux exemples d'utilisation de signatures numériques dans la vie quotidienne.

Exercice 8 – PKI et certificats numériques

1. Définir les termes suivants :
 - (a) **CA** (Certificate Authority)
 - (b) **RA** (Registration Authority)
 - (c) **CRL** (Certificate Revocation List)
 - (d) **OCSP** (Online Certificate Status Protocol)
 - (e) **Certificat numérique**
2. Expliquer le processus de **validation d'un certificat** par une chaîne de confiance (certificat racine → certificat intermédiaire → certificat final).
3. Quelle est la différence entre un certificat **DV** (Domain Validation), **OV** (Organization Validation) et **EV** (Extended Validation) ?
4. Que se passe-t-il lorsqu'un certificat est révoqué ? Comment un navigateur peut-il le vérifier ?

4 Les menaces en cybersécurité

Exercice 9 – QCM : Les menaces en cybersécurité

Pour chaque question, choisir la bonne réponse :

1. Un logiciel malveillant qui chiffre les données de la victime et demande un paiement pour les déchiffrer est :
 - (a) Un virus
 - (b) Un ransomware
 - (c) Un ver
 - (d) Un spyware
2. Le phishing est une technique d'attaque qui vise à :
 - (a) Surcharger un serveur de requêtes
 - (b) Obtenir des informations sensibles en se faisant passer pour une entité de confiance
 - (c) Exploiter une faille dans un protocole réseau

- (d) Intercepter le trafic réseau
3. Une attaque « Man-in-the-Middle » consiste à :
- (a) Surcharger un serveur
 - (b) S'intercaler entre deux parties pour intercepter ou modifier les communications
 - (c) Inonder un réseau de paquets
 - (d) Deviner un mot de passe par force brute
4. Un « zero-day » désigne :
- (a) Un virus apparu le premier jour de l'année
 - (b) Une vulnérabilité non encore corrigée et inconnue de l'éditeur
 - (c) Un type de pare-feu
 - (d) Une attaque lancée à minuit
5. La différence entre un virus et un ver est :
- (a) Il n'y a aucune différence
 - (b) Le ver se propage automatiquement sans action de l'utilisateur
 - (c) Le ver est moins dangereux
 - (d) Le virus se propage par le réseau uniquement

Exercice 10 – Types de malwares : Identification et classification

1. Compléter le tableau ci-dessous :

Malware	Définition	Mode de propagation	Exemple célèbre
Virus			
Ver			
Trojan			
Ransomware			
Spyware			
Adware			
Rootkit			
Botnet			

2. Expliquer pourquoi les ransomware représentent une menace particulièrement grave pour les entreprises aujourd'hui.
3. Quelle est la différence entre un **rootkit** et un **backdoor** ?

Exercice 11 – Ingénierie sociale et phishing

1. Citer et définir cinq techniques d'ingénierie sociale.
2. Analyser le scénario suivant et identifier la technique utilisée :

« Vous recevez un courriel semblant provenir de votre banque vous demandant de cliquer sur un lien pour vérifier votre compte. Le lien redirige vers un site identique à celui de votre banque mais hébergé sur un serveur différent. »

3. Proposer trois mesures pour se protéger contre le phishing.
4. Quelle est la différence entre le **phishing**, le **spear phishing** et le **whaling** ?

Exercice 12 – Attaques réseau : DDoS, MITM, injection

1. Expliquer le principe d'une attaque **DDoS** par amplification (par exemple via DNS ou NTP). Pourquoi ces attaques sont-elles particulièrement efficaces ?
2. Décrire deux méthodes permettant de réaliser une attaque **Man-in-the-Middle** :
 - (a) ARP spoofing
 - (b) Rogue Wi-Fi access point
3. Expliquer les différences entre les attaques par injection suivantes :
 - (a) **SQL injection**
 - (b) **XSS** (Cross-Site Scripting)
 - (c) **CSRF** (Cross-Site Request Forgery)
4. Donner un exemple de requête SQL injection permettant de contourner une authentification.
5. Expliquer le principe de l'attaque **brute force** et la différence avec une attaque par **dictionnaire**.

5 Les protections en cybersécurité

Exercice 13 – QCM : Les protections en cybersécurité

Pour chaque question, choisir la bonne réponse :

1. Un pare-feu de nouvelle génération (NGFW) se distingue d'un pare-feu classique par :
 - (a) Sa vitesse de traitement
 - (b) L'inspection approfondie des paquets et la reconnaissance d'applications
 - (c) Le nombre de règles supportées
 - (d) Son prix
2. Un IDS a pour rôle de :
 - (a) Bloquer les attaques
 - (b) Détecter et signaler les activités suspectes
 - (c) Chiffrer le trafic

- (d) Filtrer les courriels
3. L'authentification multifacteur (MFA) combine au moins :
- (a) Deux facteurs parmi : ce que l'on sait, ce que l'on possède, ce que l'on est
 - (b) Trois mots de passe différents
 - (c) Un certificat et un pare-feu
 - (d) Un VPN et un antivirus
4. Le principe du « moindre privilège » est essentiellement lié à :
- (a) La classification des données
 - (b) Le contrôle d'accès
 - (c) Le chiffrement
 - (d) La redondance
5. Un VPN assure principalement :
- (a) La confidentialité et l'intégrité des données en transit
 - (b) La disponibilité du réseau
 - (c) Le filtrage des virus
 - (d) L'anonymat complet

Exercice 14 – Pare-feu et IDS/IPS

1. Compléter le tableau comparatif :

Critère	Pare-feu classique	IDS	IPS
Action sur le trafic			
Position dans le réseau			
Mode de détection			
Réponse à une attaque			
Exemples			

2. Expliquer la différence entre un pare-feu **stateful** et un pare-feu **stateless**.
3. Quelle est la différence entre la détection par **signature** et la détection par **anomalie** (behavioral) ?
4. Où positionne-t-on un IDS/IPS dans l'architecture réseau ? Justifier.

Exercice 15 – VPN et chiffrement des communications

1. Expliquer le fonctionnement d'un **VPN site-à-site** et d'un **VPN d'accès** (remote access).
2. Compléter le tableau sur les protocoles VPN :

Protocole	Chiffrement	Port/Protocole	Sécurité
IPSec			
OpenVPN			
WireGuard			
PPTP			
L2TP/IPSec			
SSTP			

3. Expliquer les deux modes d'IPSec : **Transport** et **Tunnel**.
4. Pourquoi le protocole PPTP est-il déconseillé aujourd'hui ?

Exercice 16 – Authentification, autorisation et traçabilité

1. Définir les trois concepts du modèle AAA :
 - (a) **Authentification**
 - (b) **Autorisation**
 - (c) **Traçabilité** (Accounting)
2. Donner trois exemples de facteurs d'authentification pour chacun des types :
 - (a) **Ce que l'on sait** (knowledge factor)
 - (b) **Ce que l'on possède** (possession factor)
 - (c) **Ce que l'on est** (inherence factor)
3. Expliquer le fonctionnement du **SSO** (Single Sign-On) et citer un protocole associé.
4. Quelle est la différence entre **OAuth 2.0** et **OpenID Connect** ?
5. Expliquer le principe de l'**authentification adaptative** (adaptive authentication).

6 Gestion de la sécurité

Exercice 17 – QCM : Gestion de la sécurité

Pour chaque question, choisir la bonne réponse :

1. L'ISO 27001 porte sur :
 - (a) La gestion des incidents
 - (b) Le SMSI (Système de Management de la Sécurité de l'Information)
 - (c) Le test d'intrusion
 - (d) La cryptographie
2. Le NIST CSF comporte les fonctions :
 - (a) Identifier, Protéger, Détecter, Répondre, Récupérer

- (b) Planifier, Faire, Vérifier, Agir
 - (c) Prévenir, Détecter, Analyser, Contenir
 - (d) Classer, Chiffrer, Archiver, Détruire
3. Un test de pénétration (pentest) a pour but de :
- (a) Démontrer la conformité réglementaire
 - (b) Identifier les vulnérabilités exploitables dans un système
 - (c) Former les utilisateurs
 - (d) Déployer un pare-feu
4. L'analyse de risque en cybersécurité évalue :
- (a) Uniquement la probabilité d'occurrence
 - (b) La probabilité et l'impact d'une menace
 - (c) Le coût des équipements
 - (d) Le nombre d'utilisateurs
5. Un plan de continuité d'activité (PCA) a pour objectif de :
- (a) Prévenir les attaques
 - (b) Assurer le maintien des activités critiques après un incident
 - (c) Chiffrer les données
 - (d) Détecter les intrusions

Exercice 18 – Normes et référentiels de sécurité

1. Compléter le tableau sur les référentiels :

Référentiel	Objet principal	Type
ISO 27001		
ISO 27002		
NIST CSF		
NIST SP 800-53		
EBIOS RM		
MITRE ATT&CK		
CIS Controls		

2. Quelle est la différence entre **ISO 27001** (certification) et **ISO 27002** (bonnes pratiques) ?
3. Expliquer la méthode EBIOS RM et ses cinq phases.
4. À quoi sert la matrice MITRE ATT&CK dans la gestion de la sécurité ?

Exercice 19 – Gestion des incidents et réponse

1. Citer et décrire les six phases du cycle de vie de la gestion des incidents de sécurité (selon NIST SP 800-61).
2. Compléter le tableau suivant :

Phase	Actions clés
Préparation	
Identification	
Confinement	
Éradication	
Récupération	
Leçons apprises	

3. Quelle est la différence entre un **événement de sécurité** et un **incident de sécurité** ?
4. Donner trois bonnes pratiques pour la phase de « leçons apprises ».

Exercice 20 – Politique de sécurité et sensibilisation

1. Quels sont les composants essentiels d'une **politique de sécurité de l'information** (PSSI) ?
2. Expliquer la différence entre une **politique**, une **norme** (standard), une **procédure** et une **directive**.
3. Pourquoi la **sensibilisation des utilisateurs** est-elle souvent considérée comme la mesure de sécurité la plus importante ?
4. Proposer un plan de sensibilisation en 5 points pour une PME.

7 Manipulations : communications sécurisées

À propos de cette section

Les exercices suivants portent sur des manipulations pratiques utilisant **Wireshark** et **Kali Linux**. Si vous n'avez pas accès à un laboratoire, répondez aux questions de manière théorique en décrivant les commandes et les résultats attendus.

Exercice 21 – QCM : Wireshark et Kali Linux

Pour chaque question, choisir la bonne réponse :

1. Wireshark est un :
 - (a) Pare-feu
 - (b) Analyseur de protocoles réseau (sniffer)

- (c) Antivirus
 - (d) Générateur de trafic
2. Kali Linux est :
- (a) Une distribution Linux généraliste
 - (b) Une distribution Linux spécialisée pour le test de sécurité et le pentesting
 - (c) Un outil de chiffrement
 - (d) Un système d'exploitation pour serveurs
3. Le filtre Wireshark pour afficher uniquement le trafic HTTP est :
- (a) `port http`
 - (b) `tcp.port == 80`
 - (c) `http`
 - (d) `tcp.80`
4. Pour effectuer une capture réseau en ligne de commande, on utilise :
- (a) `netcat`
 - (b) `tcpdump`
 - (c) `ping`
 - (d) `nmap`
5. Le mode « promiscuous » sur une carte réseau permet de :
- (a) Accélérer le débit
 - (b) Capturer tous les paquets sur le réseau, pas seulement ceux adressés à la machine
 - (c) Chiffrer le trafic
 - (d) Filtrer les adresses MAC

Exercice 22 – Wireshark : Analyse de trafic réseau

1. Lancer Wireshark et capturer le trafic sur votre interface réseau pendant 2 minutes. Quels protocoles observez-vous principalement ? Décrire brièvement le rôle de chacun.
2. Utiliser les filtres d'affichage Wireshark suivants et décrire ce que chacun permet de voir :
 - (a) `ip.addr == 192.168.1.1`
 - (b) `tcp.port == 443`
 - (c) `dns`
 - (d) `arp`
 - (e) `http.request.method == "GET"`

3. Capturer une connexion HTTP (non chiffrée) et analyser :
 - (a) Les requêtes et réponses HTTP
 - (b) Les en-têtes (User-Agent, Cookie, etc.)
 - (c) Les données transmises en clair
4. Capturer une connexion HTTPS et comparer avec la capture HTTP. Quelles différences observez-vous ? Pourquoi les données sont-elles illisibles ?
5. Expliquer comment identifier une tentative d'ARP spoofing dans une capture Wireshark.

Exercice 23 – Kali Linux : Outils de base

1. Décrire les outils suivants présents dans Kali Linux et leur utilité en cybersécurité :
 - (a) **Nmap** – scan de réseau
 - (b) **Wireshark/tshark** – analyse de trafic
 - (c) **Hydra** – attaque par force brute
 - (d) **John the Ripper / Hashcat** – cassage de mots de passe
 - (e) **Aircrack-ng** – test sécurité Wi-Fi
 - (f) **Netcat** – manipulation de connexions réseau
 - (g) **Burp Suite** – test d'applications web
2. À l'aide de **Nmap**, effectuer les opérations suivantes sur un réseau local (autorise) :
 - (a) Découvrir les hôtes actifs : `nmap -sn 192.168.1.0/24`
 - (b) Scanner les ports d'un hôte : `nmap -sV 192.168.1.1`
 - (c) Détecter l'OS : `nmap -O 192.168.1.1`Décrire les résultats obtenus.
3. Quelle est la différence entre un scan **TCP SYN** (`-sS`) et un scan **TCP connect** (`-sT`) ?
4. Expliquer pourquoi l'utilisation de ces outils doit se faire **uniquement dans un cadre légal et autorisé**.

Exercice 24 – Travaux pratiques : Analyse de communications sécurisées

1. **Capture et analyse HTTP vs HTTPS** : Sur votre machine, ouvrir deux fenêtres Wireshark et effectuer :
 - (a) Une connexion vers un site HTTP (ex. `http://neverssl.com`)
 - (b) Une connexion vers un site HTTPS (ex. `https://www.google.com`)Comparer les captures : quels protocoles sont utilisés ? Peut-on lire les données dans chaque cas ? Identifier le handshake TLS dans la capture HTTPS.

2. **Analyse du handshake TLS** : Dans la capture HTTPS, identifier et décrire les messages du handshake TLS :
 - (a) Client Hello
 - (b) Server Hello
 - (c) Certificate
 - (d) Key Exchange
 - (e) Finished
3. **Commandes Kali Linux** : Exécuter les commandes suivantes et analyser les résultats :
 - (a) `openssl s_client -connect google.com:443`
 - (b) `nmap --script ssl-cert google.com -p 443`
 - (c) `nmap --script ssl-heartbleed 192.168.1.1 -p 443`
4. **Réflexion** : Pourquoi est-il dangereux d'utiliser des protocoles non chiffrés (HTTP, FTP, Telnet) sur un réseau public ? Donner trois raisons en utilisant la triade CID.